RELATÓRIO INDEPENDENTE · SEGURANÇA DE FORNECEDOR

mcp.ai sob auditoria

O que é o agregador MCP, o que ele promete, o que foi possível verificar — e por que o risco de vazamento não está onde parece.

DATA

2 de novembro de 2026

ESCOPO

mcp.ai, api.mcp.ai e conector de Open Finance

MÉTODO

verificação direta em produção, sem conta

VEREDITO

Infraestrutura real e funcional, operada por uma empresa pequena, sem certificação pública e com uma credencial estática que concentra Gmail, banco e WhatsApp. **Seguro com escopo** para Open Finance somente-leitura; arriscado para caixa de e-mail e mensagens pessoais.

Confiança alta no observado · média nas inferências

01 Quem opera

O domínio é antigo; o produto não é.

Operadora	DL WEB LTDA — CNPJ 20.873.739/0001-15, Campo Grande/MS OBSERVADO
Situação	Ativa desde 2014, capital de R$ 100 mil, um sócio-administrador, CNAE de portais e conteúdo
Domínio	mcp.ai registrado em 2019, transferido em 26/11/2024, WHOIS privado
Infra	Site em Next.js/Vercel; API em Express atrás de Cloudflare
Catálogo	2.271 conectores declarados — com dezenas de páginas derivadas do mesmo backend por banco e por prompt

02 Como funciona

Um link, muitos conectores — e um ponto onde tudo se concentra.

1

Conecta

Uma URL MCP remota: api.mcp.ai/install, com OAuth e PKCE.

2

Autentica

Pelo navegador — ou copiando um token e colando no chat.

3

Agrega

55 ferramentas no hub; o agente instala novos conectores sozinho.

4

Entrega

O pedido passa pelo mcp.ai até o provedor: Pluggy, Google, bridge própria.

O dado do seu banco vai até você por uma infraestrutura de terceiro — o que é o modelo de negócio, e também a superfície de risco.

03 Promessa e entrega

PROMESSA	O QUE FOI VERIFICADO	CLASSE
Open Finance regulado	Via Pluggy, instituição autorizada pelo BCB; o mcp.ai fica fora do perímetro regulado	OBSERVADO
Somente leitura	19 ferramentas de consulta; nenhum endpoint de Pix ou transferência	OBSERVADO
Não armazena conteúdo	Contradito pela própria documentação: arquivo de WhatsApp com busca full-text e anexos em S3	OBSERVADO
100+ servidores	2.271 no catálogo, com forte duplicação por página derivada	INFERIDO
Funciona em qualquer cliente	Protocolo responde e autentica; execução com dados reais não testada	NÃO VERIFICADO

04 Segurança: o que existe e o que falta

PRESENTE E DECLARADO

- TLS 1.3+ e credenciais cifradas em repouso (AES-256-GCM, no produto bancário)
- OAuth com PKCE S256, chaves RS256 e endpoint de revogação
- Retenção definida: tokens 30 dias após desconexão, logs 90 dias
- 2FA, passkey e step-up no painel do banco
- Política LGPD com controlador e encarregado identificados

AUSENTE (NAS PÁGINAS CONSULTADAS)

- SOC 2, ISO 27001 ou qualquer certificação independente
- Página de segurança real, security.txt e status page
- Lista pública de suboperadores e DPA
- Canal de divulgação de vulnerabilidades
- Cláusula de notificação de incidente

Contrato: serviço “como está”, responsabilidade limitada ao maior valor entre 12 meses de mensalidade e R$ 1.000. Em caso de incidente, o fornecedor responde por muito pouco — e isso é parte da avaliação.

05 Onde mora o risco

Não é “alguém invadir o mcp.ai”. É concentração de acesso com credencial de longa duração.

CONECTOR	RISCO	POR QUÊ
Banco (Open Finance)	Médio-baixo	Somente leitura, consentimento revogável no banco, trilho regulado
Gmail / Drive / Sheets	Alto	Leitura total e envio; o e-mail é a chave-mestra de reset de senhas
WhatsApp	Alto	Conexão não oficial, histórico armazenado, dados de terceiros
Instagram	Alto	Custódia de senha e automação contra os termos da plataforma

> “O token não expira.”
>
> Resposta literal da ferramenta de autenticação do mcp.ai, com a recomendação de gravá-lo na configuração do cliente.

Um único Bearer estático dá acesso a todos os conectores habilitados. Se ele vazar — configuração sincronizada, print, histórico de chat — o atacante não precisa atacar ninguém. Somam-se a isso o fluxo que manda colar o token no chat e o compartilhamento de conversa com terceiros, vendido como recurso.

06 llms.txt e IndexNow

Duas camadas diferentes, nenhuma delas um atalho para “respostas melhores”.

llms.txt é uma proposta de 2024, revisada em 2026, para dar aos agentes um índice em markdown do site. Não substitui sitemap e não é sinal de indexação documentado pelos provedores. Os laboratórios publicam o seu; isso não significa que leiam o seu.

IndexNow avisa buscadores de que uma URL mudou. Vale para Bing, Yandex, Naver, Seznam, Yep e Amazon. Google não consta. É ortogonal ao mcp.ai e ao llms.txt: não existe chamada de API que ligue um ao outro.

O que de fato melhora a resposta de um agente é contrato de ferramenta, escopo mínimo e avaliação medida — não a soma de arquivos e avisos.

07 Como usar sem se expor

1. **Nunca cole o token no chat**
   Use cabeçalho no cliente, em máquina com disco criptografado.

2. **Confirme o 2FA da conta**
   Existe no produto bancário; para a conta principal, não foi possível verificar.

3. **Olhe o app na tela do Google**
   Antes de conectar Gmail, verifique nome e selo de verificação.

4. **Prefira chaves de convidado**
   Escopo mínimo em vez de um token de dono.

5. **Revogue nos dois lados**
   No painel e no provedor; tokens duram até 30 dias após a desconexão.

6. **Exija DPA para uso corporativo**
   Lista de suboperadores, região de hospedagem e resposta a incidente.

7. **Trate o link como segredo**
   A URL do workspace e o token são credenciais de produção.

Metodologia: leitura de políticas e documentação, verificação de CNPJ e domínio, e chamadas diretas ao servidor MCP em produção. Nenhuma conta foi criada.

O que não foi testado: criptografia em repouso, identidade do app OAuth, histórico de incidentes e execução ponta a ponta com dados reais.